Job Scout: AI risk register

GROUPED BY THE NIST AI RISK MANAGEMENT FRAMEWORK
OWNERS: CODE · LOCAL MODEL · CLOUD AGENT · USER
REVIEWED AT EVERY SPRINT CLOSE

Data map (privacy tiers). The mailbox is seen only by code on the PC; adverts and replies only by a tool-less local model, which passes checked summaries to the cloud; the career vault only by the cloud writer and the read-only reviewer; the Bridge password by nothing.

	RISK	CONTROL	BACKLOG	OWNER	HOW IT IS CHECKED	STATUS	LAST
Govern	**The scout acts for the user: applies, replies, accepts, books or edits a profile**	Hard boundaries in every procedure and task prompt; packs and cards are drafts; only agreed reply rules move a card	H1, I4	User	Prompts and procedures read at each sprint close; red team RT8	Holding	17 Oct
	An application claims more than their record supports	Positioning rules; barred words fail the build; a read-only reviewer checks every claim against the vault, one revision, the rest to sign-off	H6, G6	cloud agent	Reviewer hand-checks 09 to 16 (8 of 8 pass); validate.py claims on every live pack (and sentences, BUG-6)	Holding; no read-only agent in scheduled runs (G10); passes can disagree (H21)	21 Oct
	AI use on a form answered inconsistently or untruthfully	One approved answer, word for word in every pack	H11	code	validate.py disclosure in every pack.json; the reviewer's verdict	Holding	21 Oct
	Nobody can tell what ran, on which instructions and model	A ledger entry for every step: agent, model, digest, instruction and input hashes, counts	H7	code	Weekly runs-by-model table; digest warning on a model change	Holding	17 Oct
Map	**A secret reaches an agent or a synced folder**	Bridge password encrypted for the local Windows account, outside every folder a task can reach	H1	code	run.md warns while .env still holds a password	Holding	15 Oct
	Strangers' personal data kept without reason	Raw emails only in the private store, 30 days; adverts, specs and reply summaries 90 days unless applied for; no contact details on a card	H14, H10	code	Retention and card tests; a retention line in every run.md	Built	17 Oct
	Data reaches the cloud that should stay on the PC	The privacy tiers above (ARCHITECTURE.md); replies leave the PC as type, dates and a 200-character ask; staleness as hashes and reasons	H5, I2	code	Red team RT5 and RT10; reply validator	Holding	17 Oct
	Personal details reach the public demo copy	An export copies only an allow-list, lays a neutral template over it and scans every file, Word and PDF too, for the owner's names, applications, domain, board ids, paths and keys; the user checks the images and pushes	H22, H24	User	npm run export fails on any find; two audits and a fresh-clone check (21 Oct); a refresh writes only the plan, never .git	Holding; images checked by eye	22 Oct
Measure	**Judgement drifts unseen after a model, rubric or procedure change**	Evaluation set labelled by the user; flag at 10 points down or any new false negative; model digest pinned	H8	User	EVAL.md before every change; weekly line	First run 17 Oct; no baseline yet (H18)	17 Oct
	The local reader misreads requirements or pay	Grounding check against the advert's own words; 23-advert reader set	H5, H8	local model	npm run eval:reader --repeat 3: 21 of 22 in each run (bar 9 in 10)	Holding; the 19 Oct fall was the test (H19)	21 Oct
	The reply reader misreads a reply	The user grades it: 10 or more, 9 in 10 right, no rejection read as an invitation; until then every move is a suggestion	I2, I4	User	npm run grade-replies	Not graded yet	Not run
	Defences that pass unit tests fail in practice	Quarterly red team through the real pipeline, scratch data only; each failure a BUG row	H9	User	npm run redteam, then REDTEAM.md; reminder each quarter (BUG-2 fixed)	First full run: 10 of 10 held	17 Oct
Manage	**Prompt injection in an alert, advert or reply steers the AI**	Every field cleaned and capped before the AI (the alert subject since BUG-1); text held between markers as data	H2	code	Hostile fixtures; red team RT1 to RT3, RT6, RT9, RT10	Holding	17 Oct
	A malformed or manipulated output is written	Every score, card, pack, claim, reply summary, move and board document checked before writing; failures to Problems	H3	code	validate.py on every write	Holding	17 Oct
	A run misbehaves while they are away, or costs too much	Pause switch; adverts, packs and rebuilds capped per run; each run's estimated cost on the Runs tab	H4, G11	User	Board Settings, read first by every part; validate.py runlog	Holding; live since 23 Oct	23 Oct
	A sent pack is changed, or a stale one sent unnoticed	Rebuilds go to a new folder and the user chooses; only Draft cards are flagged or rebuilt	E15, E16	code	validate.py packpatch and pack; the card's freshness badge	Built; nested folders fixed (BUG-8)	23 Oct
	A card moves to the wrong column, or a reply is missed	Matched by thread, sender, company and role; moves only for a verified, fully read reply after grading, never in the first look; logged, with Undo	I1, I3, I4, I6	code	validate.py moves; Undo on the card; watch list	Suggestions only; one reply missed (I9)	21 Oct
	The scout overwrites their ticks or chosen slots	Inbox, to-do and calendar documents are create-only	I5, I7	code	validate.py docs	Built	17 Oct
	A fake recruiter or phishing email is trusted	Senders judged by address and DKIM, never display name; links never opened; asks quoted, never acted on	I1, I2	code	Inbox tests; red team RT5 and RT8	Holding	17 Oct
	A sleeping PC silently loses a morning	Wake task on mains; the cloud parts report an unreachable PC; power settings (sleep never on mains)	G7, G4	code	The morning message; the runbook's incident log	Stops and repeats handled (BUG-9, G4)	23 Oct
	The local model runs on the processor and stalls	Speed warning; below 15 tokens a second the reader stops after one advert and part 2 reads the rest in the cloud	H5, G9	code	specs\summary.json speed and skippedSlow; the digest	Fired live 22 Oct: one advert read, four left to the cloud	22 Oct

Not yet built: I8 (export to their own calendar). H15, H16 (Sprint 8), E15 and E16 (Sprint 10) await their first live use. **Residuals:** the reply reader moves nothing until graded; no scoring baseline until H18; a long advert can lose its last requirements (H20); run costs are estimates (G11).